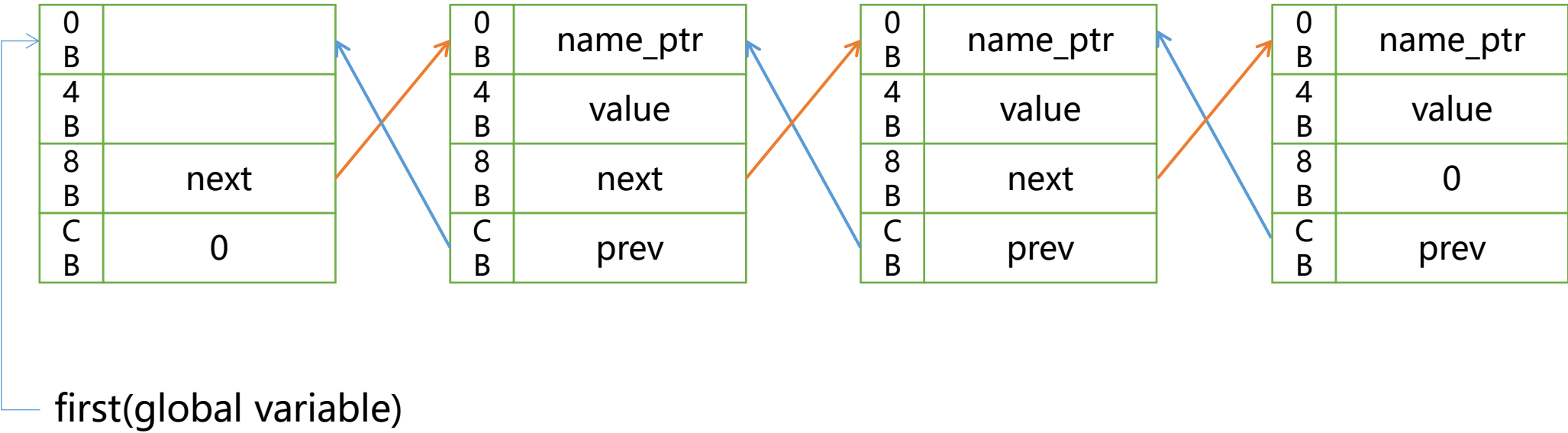
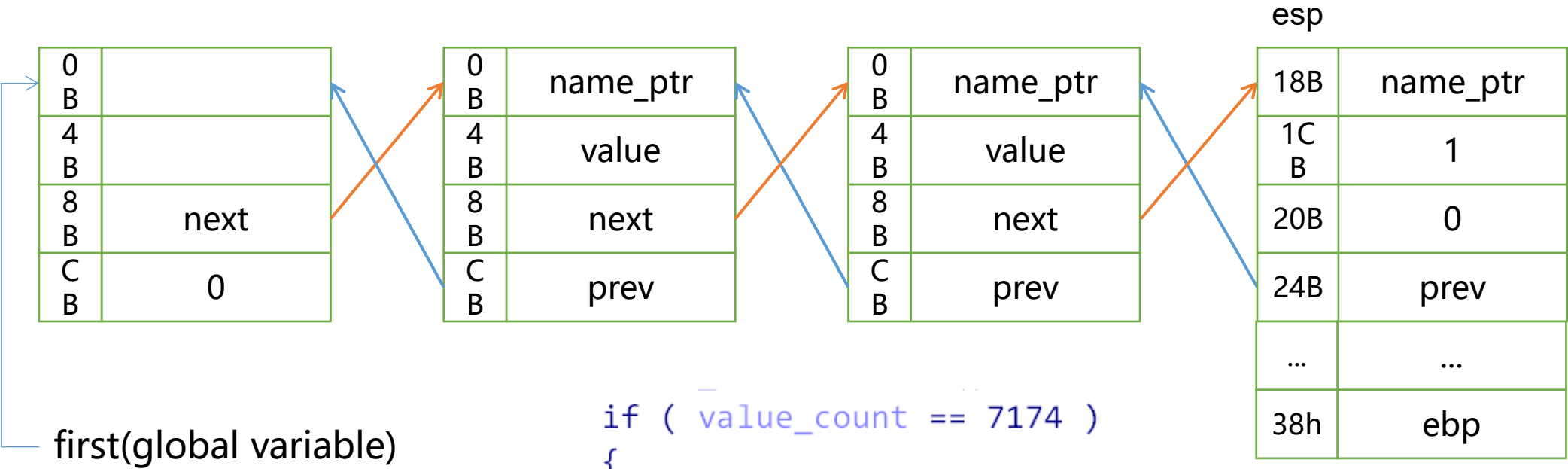


name	"iphone 4"	"iphone 5"	"iphone 6"	"iphone 7"
------	------------	------------	------------	------------



name	"iphone 4"	"iphone 5"	"iphone 6"	"iphone 7"
------	------------	------------	------------	------------

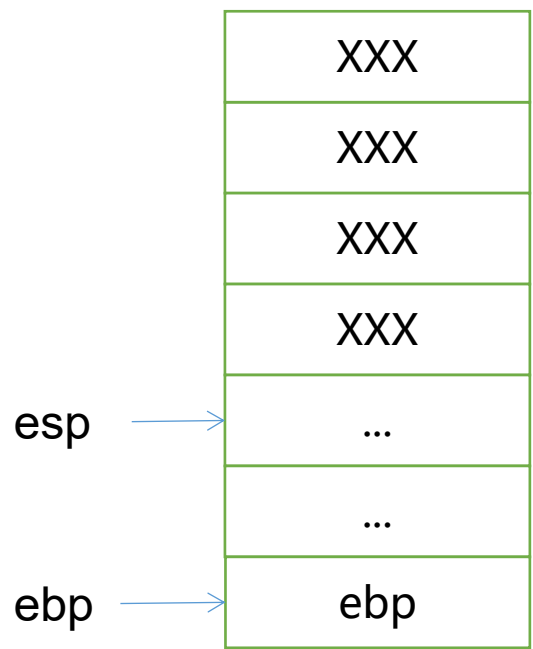


```

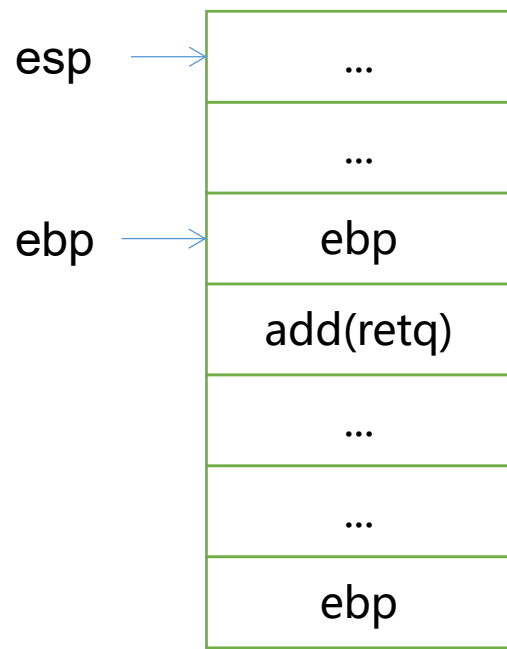
if ( value_count == 7174 )
{
    puts("*: iPhone 8 - $1");
    asprintf(&v2, "%s", "iPhone 8");
    v3 = 1;
    insert((int)&v2);
    value_count = 7175;
}

```

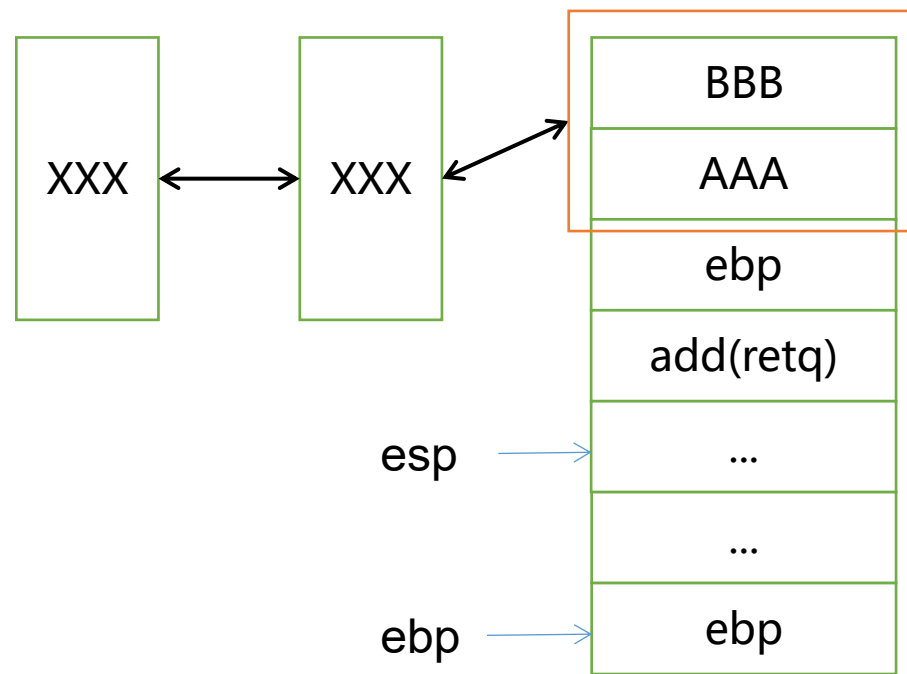
stack



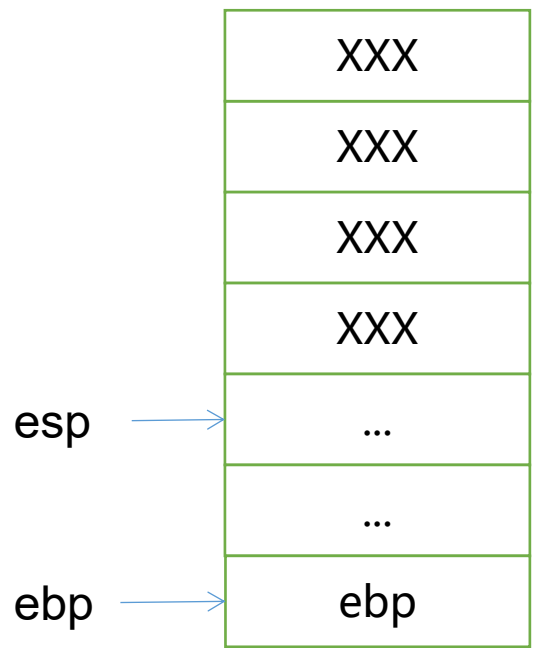
before checkout()



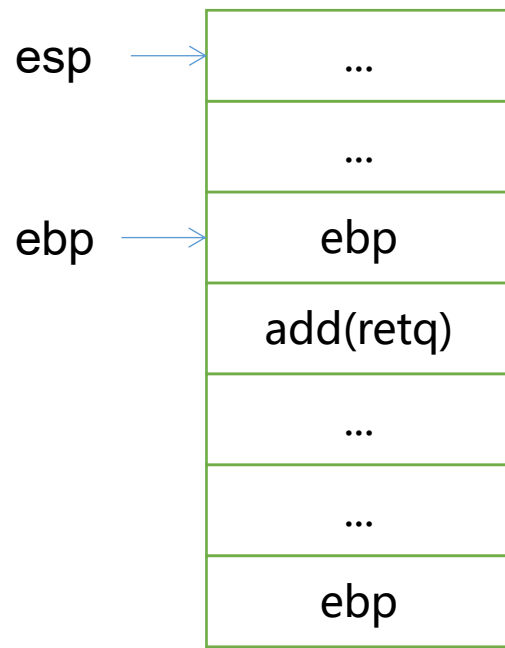
in checkout()



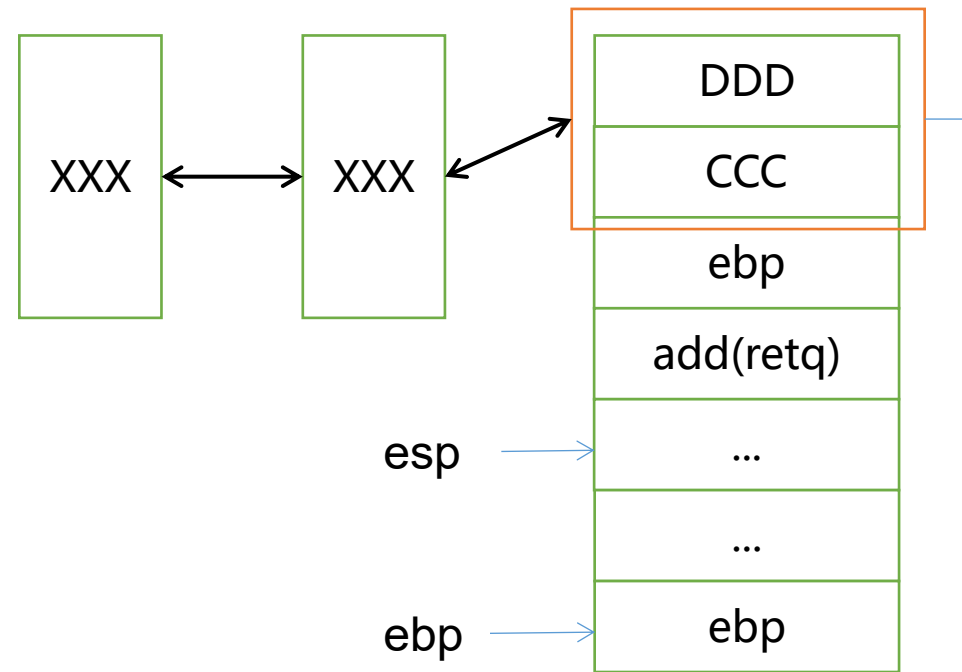
after checkout()
before cart()



before checkout()



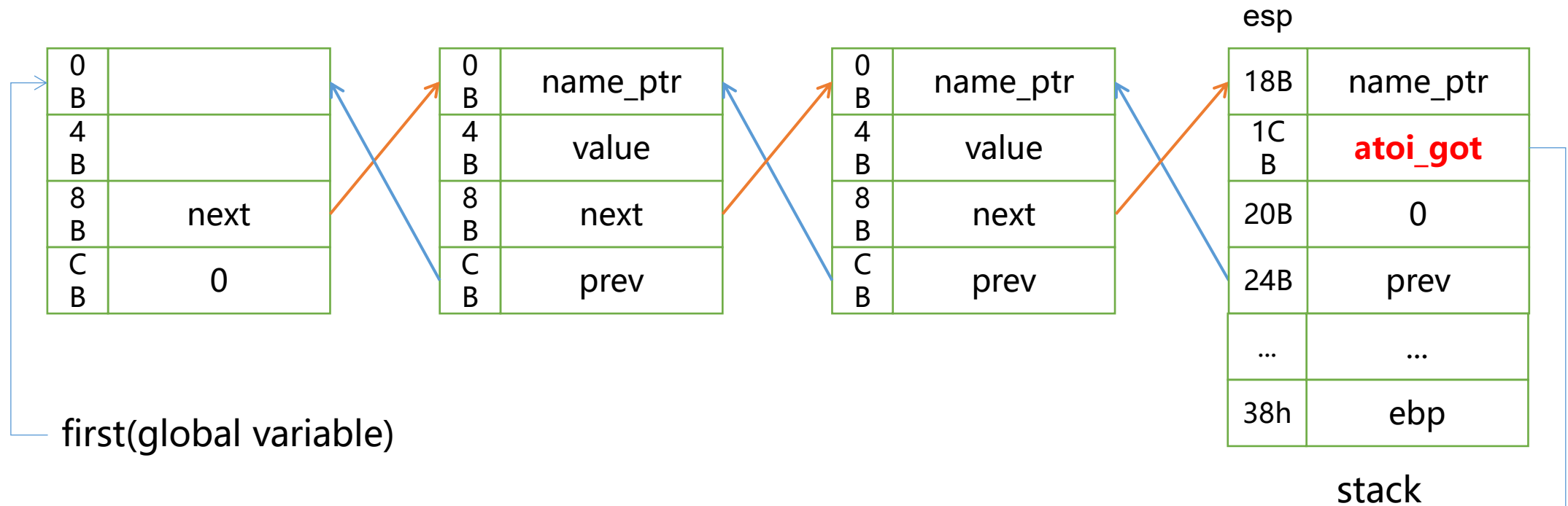
in checkout()



after cart()

other func can change this data
so maybe can leak information of link

name	"iphone 4"	"iphone 5"	"iphone 6"	"iphone 7"
------	------------	------------	------------	------------



cart() will print each value
we can get libc address!

next? emmm...double link? Wonderful! Unlink may be successful!

esp

18B	name_ptr
1CB	1
20B	0
24B	prev
...	...
38h	ebp

stack

esp

18B	name_ptr
1CB	1
20B	atoi_got - 8
24B	system_addr
...	...
38h	ebp

stack

call delete

$(cur \rightarrow prev) \rightarrow next = cur \rightarrow next$
 $(cur \rightarrow next) \rightarrow prev = cur \rightarrow prev$

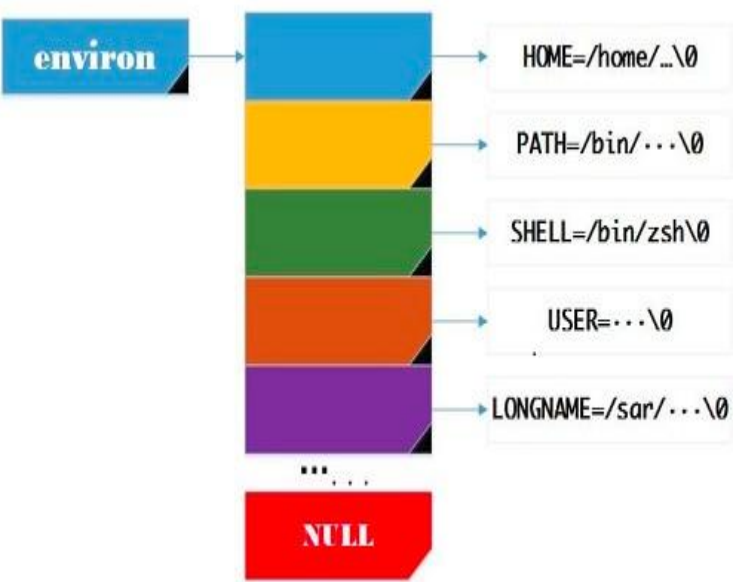
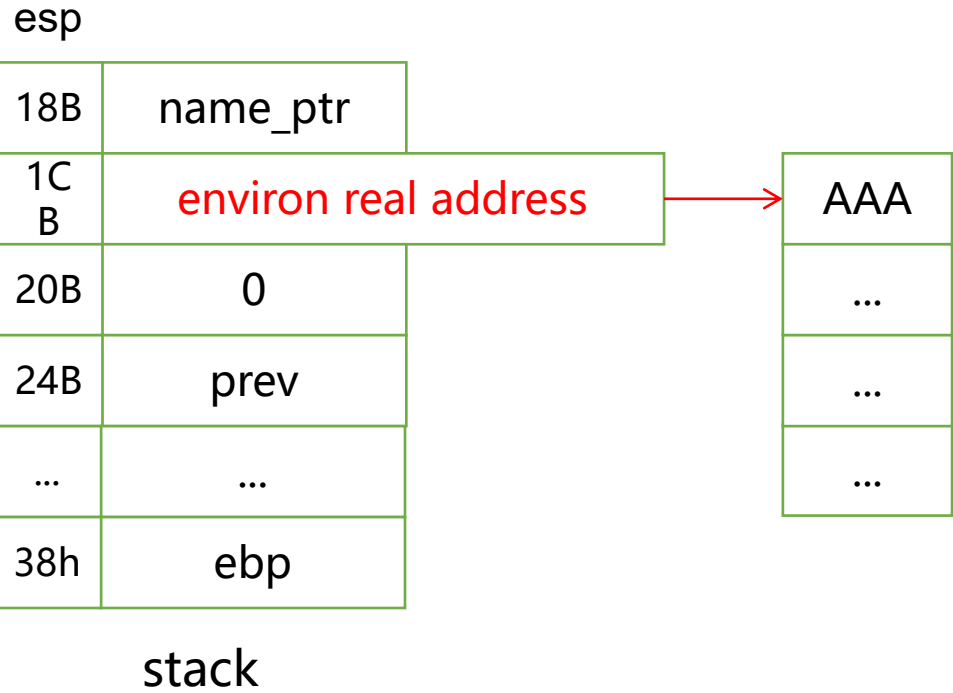
$(atoi_got - 8) + 8 = system_addr$
 $(sys_addr) + 12 = atoi_got$

$atoi_got = system_addr$
 $sys_addr + 12 = atoi_got$

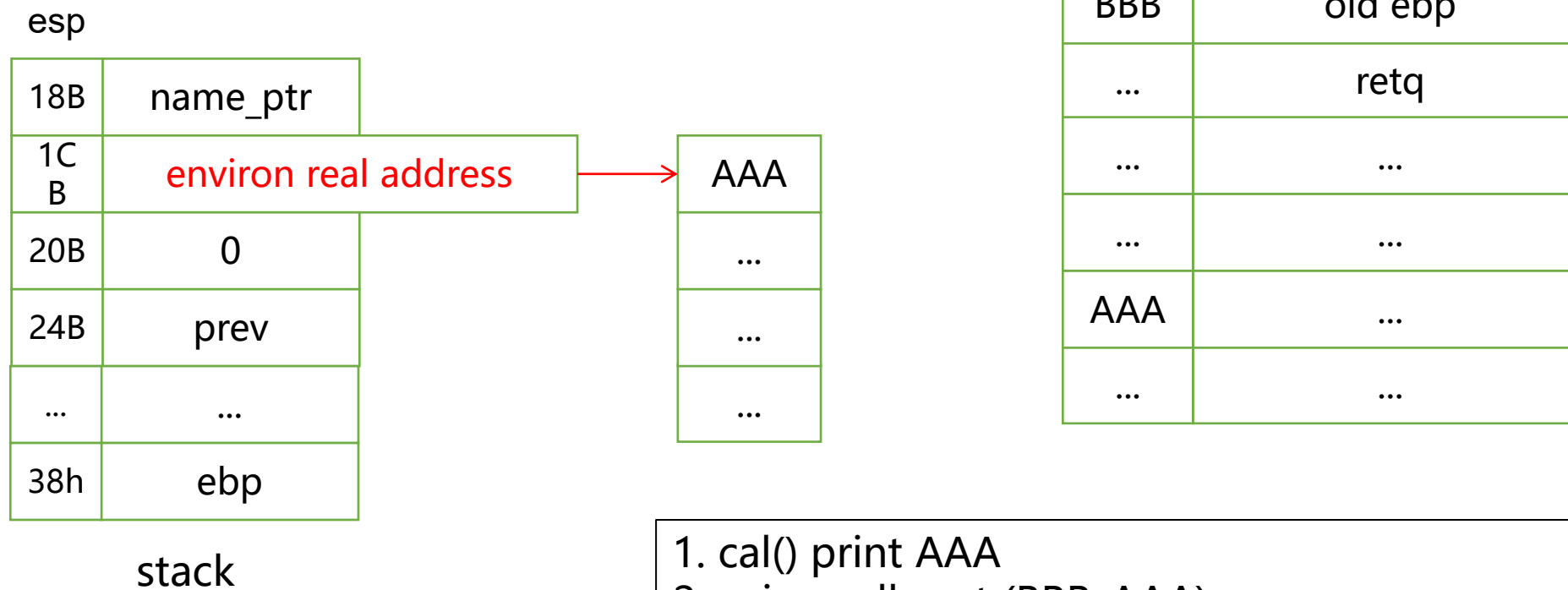


system_addr + 12 : Unwritable!!!!

Unlink not work, **using environ**



Unlink not work, **using environ**



1. cal() print AAA
2. using gdb get (BBB-AAA)
3. we can get BBB, that is cal() stack base
4. by assembly code, we can get all function stack base

What we can do is just unlink...

esp

18B	name_ptr
1C B	1
20B	0
24B	prev
...	...
38h	ebp

stack

esp

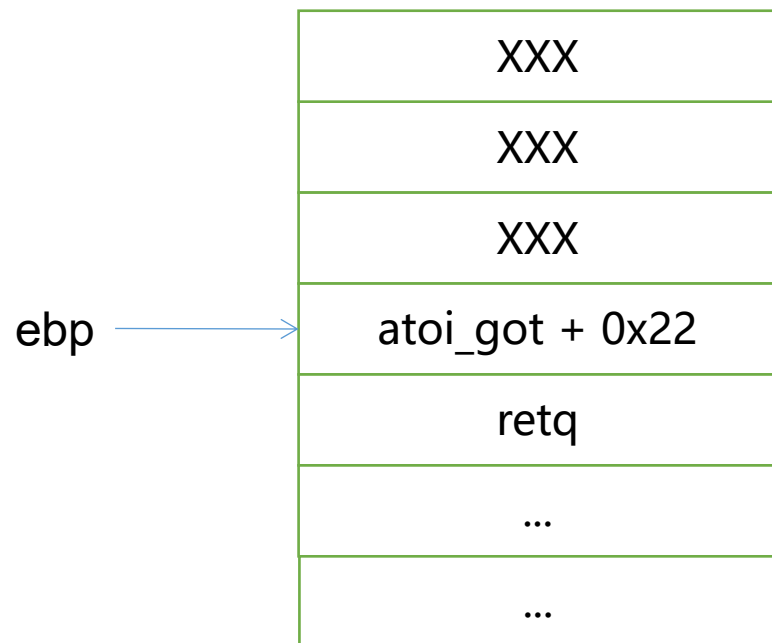
18B	name_ptr
1C B	1
20B	atoi_got + 0x22
24B	del_ebp - 8
...	...
38h	ebp

stack

call delete

$$\begin{aligned}(\text{atoi_got} + 0x22) + 12 &= \text{del_ebp} - 8 \\ (\text{del_ebp} - 8) + 8 &= \text{atoi_got} + 0x22\end{aligned}$$

$$\begin{aligned}\text{atoi_got} + 0x2C &= \text{del_ebp} - 8 \\ \text{del_ebp} &= \text{atoi_got} + 0x22\end{aligned}$$



leave ret(del func)

下面回到主函数继续输入
choice

my_read(&choice, 0x15u)

switch(atoi(&choice))

ebp-0x22	choice	atoi_got
ebp-0x20		
...	...	
ebp-0x0E	...	
ebp-0x0C	cookie	
ebp-0x0A		
...	...	
ebp-0x04	...	
ebp-0x02	...	
ebp	...	atoi_got + 0x22

leave ret(del func)

下面回到主函数继续输入
choice

`my_read(&choice, 0x15u)`

`switch( atoi( &choice) )`

ebp-0x22	system	atoi_got
ebp-0x20		
...	sh	
ebp-0x0E	...	
ebp-0x0C	cookie	
ebp-0x0A		
...	...	
ebp-0x04	...	
ebp-0x02	...	
ebp	...	atoi_got + 0x22

leave ret(del func)

下面回到主函数继续输入
choice

my_read(&choice, 0x15u)

switch(atoi(&choice))

ebp-0x22	system	atoi_got
ebp-0x20		
...	sh	
ebp-0x0E	...	
ebp-0x0C	cookie	
ebp-0x0A		
...	...	
ebp-0x04	...	
ebp-0x02	...	
ebp	...	atoi_got + 0x22

```

leave ret(del func)
下面回到主函数继续输入
choice
my_read(&choice, 0x15u)
switch( atoi( &choice) )

```

相当于执行 **system("system||sh")**